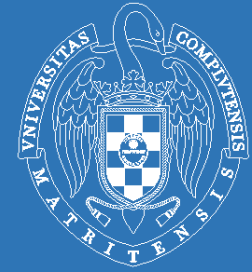


Módulo 1. Seguridad en redes

Vulnerabilidades en protocolos de red y ataques



Inmaculada Pardines - Marcos Sánchez-Élez -
Guadalupe Miñana - Sara Román - Eduardo Huedo

Módulo TCP/IP (resumen)

- Los datos provienen de la capa de aplicación
- La capa de transporte asigna los números de secuencia, establecimiento de sesión y transmisión.
- Luego los datos se pasan a la capa de red, donde se agrega información de enrutamiento a cada paquete las direcciones IP de origen y destino.
- Luego la trama pasa a la capa de enlace, que debe encontrar la dirección MAC que se agregan a la parte del encabezado de la trama.

Vulnerabilidades en protocolos de red

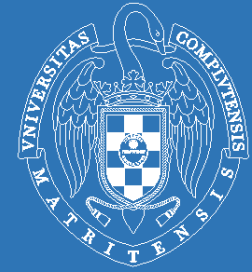
- **Todos los protocolos de red** (IP, ICMP, ARP, TCP, UDP, DNS, HTTP) **son vulnerables** porque:
 - ✓ Se definieron sin tener en cuenta la seguridad (excepto WiFi)
 - ✓ No proporcionan confidencialidad, ni integridad, ni autenticidad de origen
- Posteriormente, han aparecido versiones orientadas a proporcionar seguridad (IPsec, DNSSEC, HTTPS ...)

Tipos de ataques

- Escucha (sniffing) -> *Confidencialidad*
 - Conseguir leer la información de los paquetes que circulan por la red
- Intermediario (Man-in-the Middle) -> *Confidencialidad, Integridad, Autenticidad*
 - Conseguir que todos los paquetes de la red pasen por un servidor/encaminador particular en su camino hacia su destino final
- DoS, DDoS -> *Disponibilidad*
 - Un ataque de denegación de servicio (DoS) inunda un servidor con tráfico, lo que hace que un sitio web o recurso deje de estar disponible.
 - Un ataque de denegación de servicio distribuido (DDoS) es un ataque de DoS que utiliza múltiples computadoras o máquinas para inundar un recurso específico.
- Falsificación (spoofing, rogue) -> *Confidencialidad, Integridad, Disponibilidad, Autenticidad*
 - Hacerse pasar por el servidor, dispositivo destino de la comunicación
- Secuestro (hijacking)/ suplantación de conexión -> *Confidencialidad, Integridad, Disponibilidad, Autenticidad*
 - Secuestro de conexión, servidores, dispositivos ..., hacerse con el control total de alguno de esos sistemas

Módulo 1. Seguridad en redes

Vulnerabilidades en protocolos de red y ataques



CAPA DE ENLACE: ETHERNET

ETHERNET

Las microcomputadoras evolucionaron y se utilizaron en muchas oficinas y áreas de trabajo. Poco a poco, los terminales tontos se volvieron un poco más inteligentes y potentes a medida que los usuarios necesitaban compartir recursos. Y ¡bam! Se desarrolló Ethernet, lo que permitió una verdadera conexión en red.

CISSP All in One

- Ethernet es una tecnología de LAN compartida que permite que varios dispositivos se comuniquen en la misma red. Ethernet suele utilizar una topología de bus (cable lineal) o estrella (interruptor).
- Ethernet aborda cómo compartir una red común y cómo se relacionan con colisiones, integridad de datos, mecanismos de comunicación y controles de transmisión.
- Ethernet se define por las siguientes características:
 - ✓ Comparte medios. (Todos los dispositivos deben turnarse para usar el mismo medio, y pueden producirse colisiones.)
 - ✓ Utiliza dominios de difusión y colisión.
 - ✓ Utiliza el acceso múltiple con detección de portadora con detección de colisiones (CSMA/CD).
 - ✓ Admite full duplex en implementaciones de par trenzado.
 - ✓ Puede utilizar medios coaxiales o de par trenzado.
 - ✓ Está definido por el estándar IEEE 802.3

Ethernet

- No proporciona **confidencialidad**, ni **integridad**, ni **autenticidad** de origen

Vulnerabilidades del protocolo

- Se puede **leer y analizar el tráfico** (wireshark o tcpdump)
 - Muchos protocolos (HTTP, FTP, TELNET, POP, IMAP...) envían las contraseñas en claro
- Se pueden **alterar tramas o generar tráfico falso**

Ejemplos de ataques

- Escucha (*sniffing* o *eavesdropping*)
- Suplantación de direcciones MAC (*MAC spoofing*)

Posibles contramedidas

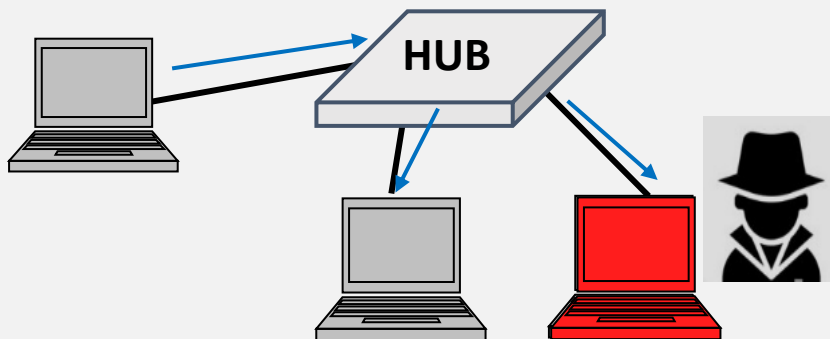
- Seguridad MAC (IEEE 802.1AE o MACsec)
 - Claves de cifrado, autenticación de mensajes y comprobación de direcciones MAC

Ethernet

- ¿Cómo se puede realizar un ataque de **escucha**?

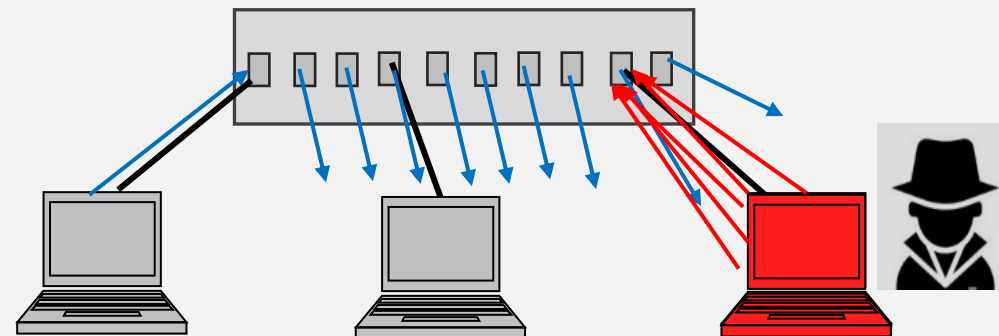
Red de difusión

- Las tramas llegan a todos los nodos
- Si el atacante está dentro de la red recibe todas las tramas



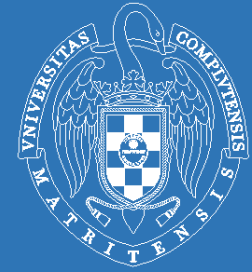
Red de conmutación

- Si la MAC destino está en la tabla de conmutación del switch la trama se envía solo al destino, si no se envía por todos los puertos
- Pasos del ataque:
 - Inundación con paquetes con direcciones MAC aleatorias (*MAC spoofing*)
 - La tabla de conmutación se llena, no caben las MACs de la LAN
 - El envío a una MAC que no está en la tabla, se reenvía por todos los puertos ▶ **Switch que se comporta como hub**



Módulo 1. Seguridad en redes

Vulnerabilidades en protocolos de red y ataques



CAPA DE RED: ARP, IP, ICMP

ARP (Address Resolution Protocol)

- En una red TCP/IP, cada computadora y dispositivo de red requiere una dirección IP única y una dirección de hardware física única.
- Cada tarjeta de red tiene una dirección física única que el fabricante programa en los chips ROM de la tarjeta. La dirección física también se conoce como dirección de control de acceso al medio (MAC).
- La **capa de red** trabaja y comprende las direcciones IP, y la **capa de enlace** trabaja y entiende las direcciones MAC.
 - ✓ Cuando una trama llega al cable, solo sabe hacia qué dirección MAC se dirige.
 - ✓ Las direcciones MAC e IP deben estar asignadas correctamente para que puedan resolverse correctamente, a través del Protocolo de resolución de direcciones (ARP).
 - ✓ Cuando la capa de enlace recibe una trama, esta tiene la dirección IP de destino, pero la capa de enlace no puede comprender la dirección IP y, por lo tanto, invoca ARP en busca de ayuda.
 - ✓ ARP transmite una trama solicitando la dirección MAC que corresponde con la dirección IP de destino.
 - ✓ Cada computadora en la subred recibe esta trama de transmisión y todas, excepto la computadora que tiene la dirección IP solicitada la ignora. La computadora que tiene la dirección IP de destino responde con su dirección MAC.
 - ✓ Ahora ARP sabe qué dirección de hardware corresponde con esa dirección IP específica. La capa de enlace de datos toma el marco, le agrega la dirección de hardware y la pasa a la capa física, lo que permite que la trama llegue al cable y vaya a la computadora de destino.

Una dirección MAC es única porque los primeros 24 bits representan el código del fabricante y los últimos 24 bits representan el número de serie único asignado por el fabricante a esa tarjeta de red, ...

ARP

- No proporciona **integridad** ni **autenticidad** de origen

Vulnerabilidad

- Se pueden enviar **mensajes falsos** para insertar entradas maliciosas en la *cache* ARP -> **envenenamiento de la cache ARP** (*ARP spoofing* o *ARP cache poisoning*)

Tipos de ataque

- Intermediario (*Man in the Middle*)
- Denegación de servicio (*Denial of Service, DoS*)

Posibles contramedidas

- Tablas ARP estáticas
- Detección de cambios
- Escucha DHCP (*DHCP snooping*)
- Seguridad MAC

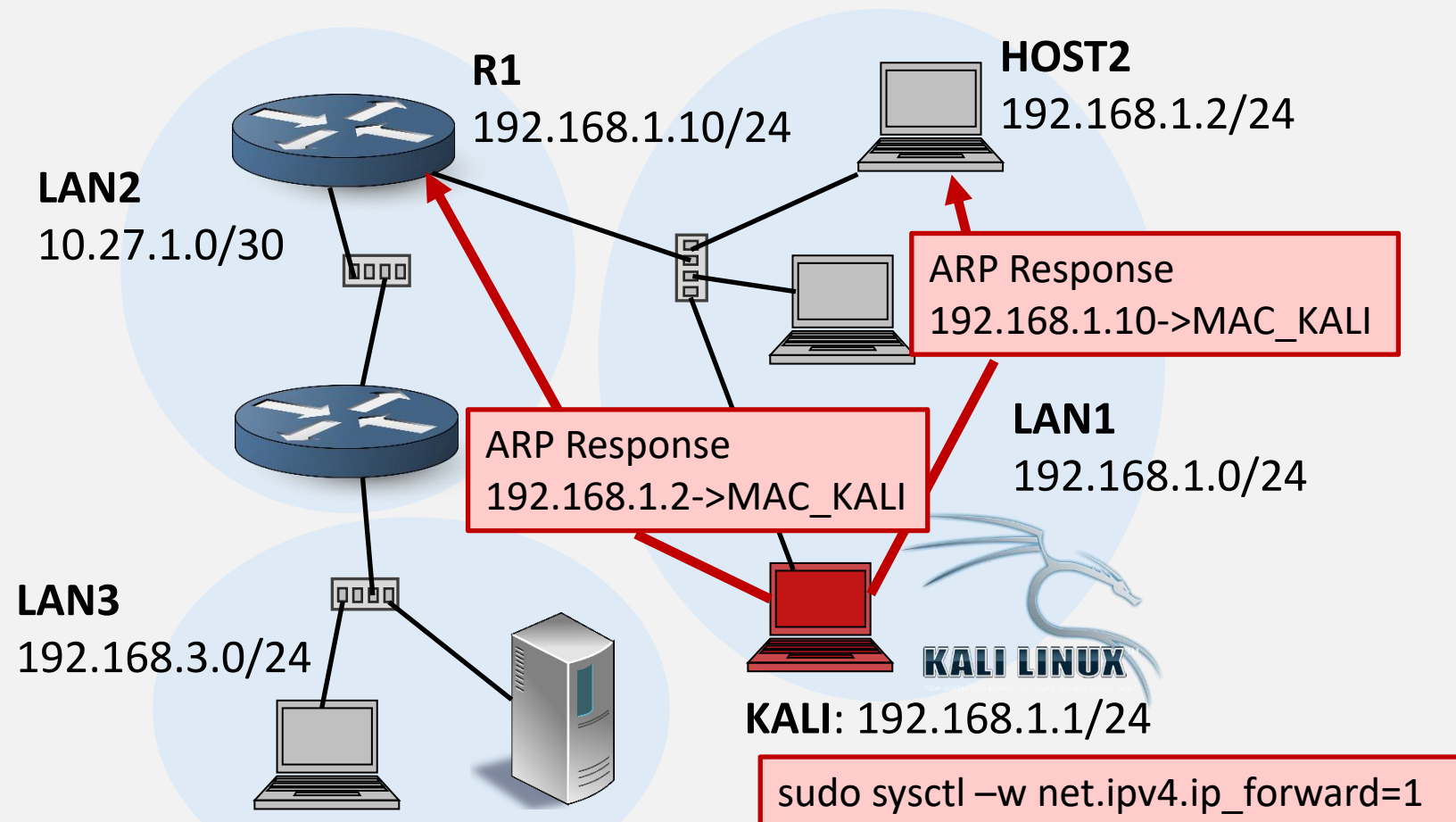
Envenenamiento de cache ARP

- **Posibles tipos de ataque:**

- **Intermediario:** el tráfico dirigido desde la víctima a otra máquina pasa primero por el atacante
 - ✓ Asociar la dirección **MAC del atacante** con la dirección **IP de la máquina a la que dirige el tráfico la víctima**, provocando que el tráfico dirigido desde la víctima a esa máquina se envíe primero al atacante
 - Es necesario haber activado el *forwarding* para poder reenviar los mensajes capturados y que los mensajes lleguen finalmente a destino
 - ✓ Se suele envenenar la tabla de la máquina víctima y la del *router* por defecto, así todo el tráfico de la víctima con el exterior pasa por el atacante
- **Denegación de servicio:** los mensajes nunca llegan a su destino
 - ✓ Asociar la dirección **IP de la máquina a la que dirige el tráfico la víctima** a una **MAC inexistente**
 - ✓ **NO activar el forwarding** en la máquina atacante por lo que no puede reenviar los mensajes capturados

Envenenamiento de cache ARP

- **Intermediario:** Una máquina atacante envía mensajes ARP falsos en una LAN modificando el contenido de las tablas ARP con una asociación IP-MAC falsa



Envenenamiento de cache ARP

- La técnica usada en la suplantación de mensajes ARP no se puede prohibir porque a veces se usa para implementar redundancia
 - ✓ Algunas herramientas permiten que un servidor envíe mensajes ARP no solicitados (*gratuitous*) para tomar el control de un servidor defectuoso y así ofrecer redundancia de forma transparente
- Algunas herramientas con las que se consigue producir un ataque de este tipo son: arpspoof, nping, ettercap...
- Este ataque solo funcionará si el atacante se encuentra en la misma red que la máquina víctima

IP (Internet Protocol)

- Una dirección IP es un identificador único (dentro de la red a la que pertenece) asignado a un dispositivo o dominio que se conecta a Internet.
- Sirve para que un paquete puede llegar desde una red a otra distinta.
- Los paquetes IP se crean al añadir un encabezado IP a cada paquete de datos antes de enviarlo. Un encabezado IP no es más que una serie de bits (unos y ceros), y registra varios datos sobre el paquete, como la dirección IP de envío y de recepción.
- Cada paquete IP contendrá tanto la dirección IP del dispositivo o dominio que envía el paquete como la dirección IP del destinatario.
- Los encabezados IP también informan de:
 - ✓ Longitud del encabezado
 - ✓ Longitud del paquete
 - ✓ Tiempo de vida (TTL), o el número de saltos de red que puede hacer un paquete antes de ser descartado
 - ✓ El protocolo de transporte que se está utilizando (TCP, UDP, etc.)
 - ✓ ...

IP

- **No** proporciona **integridad** ni **autenticidad** de origen

Vulnerabilidad

- Se pueden **falsificar mensajes IP**, por ejemplo, usando una dirección IP de origen arbitraria → **IP address spoofing**
 - La respuesta se enviará a la dirección falsificada
 - El atacante mantiene el anonimato

Tipos de ataque

- DoS reflejado
- Acceso no autorizado

Posibles contramedidas

- Filtrado de entrada/salida (ingress/egress filtering)
- Seguridad IP (IPsec)

ICMP (Internet Control Message Protocol)

El Protocolo de mensajes de control de Internet (ICMP) es básicamente el “recadero” de IP. ICMP entrega mensajes de estado, informa errores, responde a ciertas solicitudes, informa del enrutamiento y se utiliza para probar la conectividad y solucionar problemas en redes IP.

CISSP All in One

- Realizamos un ping (ICMP) cuando queremos conocer la conectividad de un sistema:
 - ✓ Esto implica enviar tramas ICMP ECHO REQUEST.
 - ✓ Esperando recibir de vuelta tramas ICMP ECHO REPLY
 - ✓ Si en un lapso de tiempo predefinido no se ha recibido respuesta (REPLAY) a un ICMP REQUEST se enviarán más tramas ECHO REQUEST. Si sigue sin producirse respuesta se indicara que el host no es alcanzable (unreachable).
 - ✓ ICMP también indica cuándo ocurren problemas con una ruta específica en la red e informa a los routers circundantes sobre las mejores rutas a tomar en función del estado y la congestión de las distintas rutas.
 - ✓ Los routers utilizan ICMP para enviar mensajes en respuesta a datagramas que no se pudieron entregar. El encaminador selecciona la respuesta ICMP adecuada y lo envía de vuelta al host solicitante, indicando que se encontraron problemas con la solicitud de transmisión.
 - ✓ Hacer un ping a una IP de una máquina que no es de tú propiedad puede considerarse la primera fase de un ataque y, por lo tanto, un delito.

ICMP

- No proporciona **integridad** ni **autenticidad** de origen

Vulnerabilidad

- Se pueden generar **mensajes de control falsos**:
 - ICMP redirect
 - ICMP time exceeded...

Tipos de ataques

- Intermediario
- DoS

Posibles contramedidas

- Ignorar peticiones sospechosas
- Seguridad IP (IPsec)

Redirección ICMP (ICMP redirect)

- **Escenario:** Un atacante falsifica mensajes ICMP *Redirect* para modificar las tablas de rutas de la víctima
- **Tipos de ataque:**
 - **Intermediario**
 - Hace que la víctima envíe paquetes para ciertas conexiones a través del atacante
 - **Denegación de servicio**
 - Deja algunos equipos inaccesibles creando bucles o agujeros negros
- **Herramientas** para generar este ataque: `hping...`

ICMP

Vulnerabilidad

- Las respuestas **consumen recursos**
 - Consume ancho de banda en ambos sentidos -> Inundación ICMP(**ICMP Ping flooding**)
 - Normalmente, con una IP de origen falsa
 - El atacante mantiene el anonimato

Tipos de ataque

- DoS

Posibles contramedidas

- Cortafuegos
- IDS

Inundación ICMP (*ICMP/Ping Flooding*)

- **Escenario:** Un atacante envía multitud de paquetes ICMP *Echo Request* a la víctima
 - ✓ La opción -f (*flood*) de ping (solo para *root*) envía paquetes ICMP lo más rápido posible, sin esperar respuesta
 - Esta opción existe para diagnosticar problemas de pérdidas de paquetes o productividad de la red (uso no malicioso)
- **Tipo de ataque:** **Denegación de servicio**
 - ✓ Tiene éxito si el atacante tiene más ancho de banda que la víctima
 - El atacante espera que la víctima responda con paquetes ICMP *Echo Reply*, consumiendo así ancho de banda saliente y entrante
 - ✓ También consume CPU
- **Herramientas** para generar este ataque: ping, nping, hping...

ICMP

Vulnerabilidad

- El protocolo ICMP genera **respuestas a peticiones maliciosas**
 - Se pueden forzar las respuestas mayores, en número o tamaño, que las peticiones → ***smurf attack***

Tipos de ataque

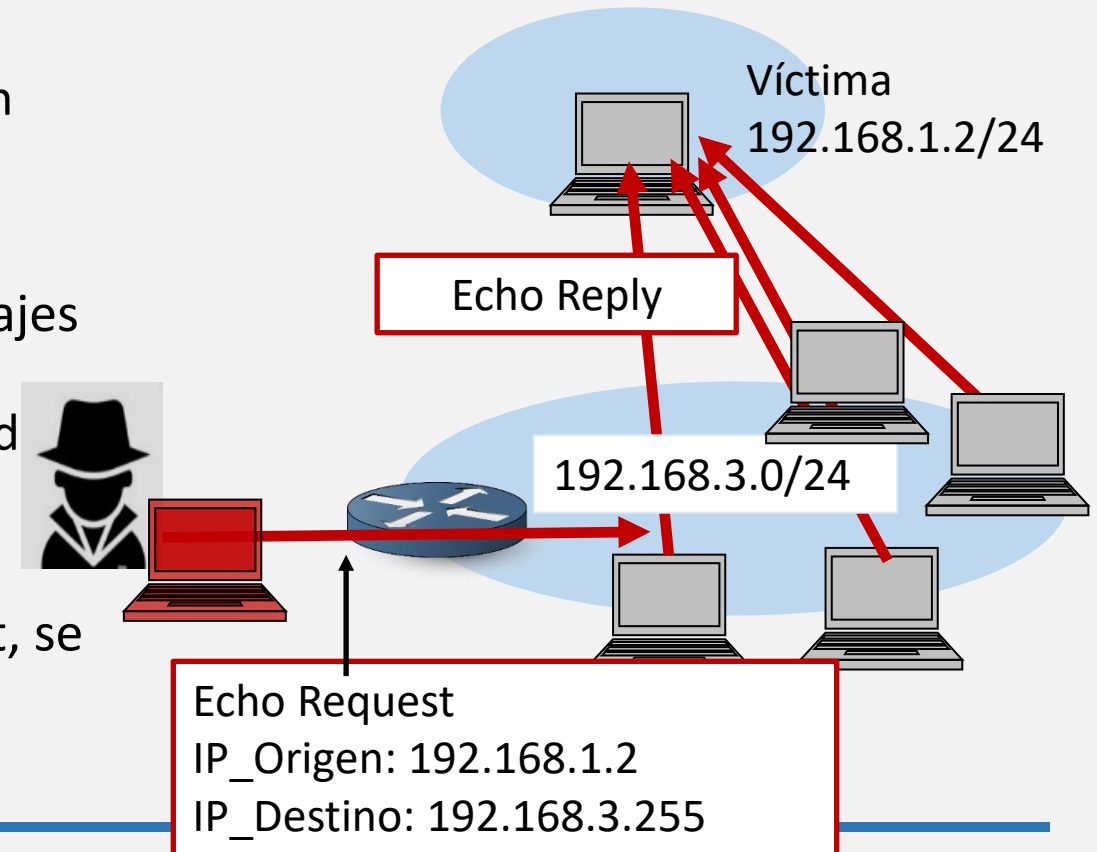
- DoS amplificado
 - Puede tener éxito incluso con poco ancho de banda, gracias al efecto de la amplificación

Posibles contramedidas

- No responder a peticiones sospechosas
- Cortafuegos

Smurf attack

- **Escenario:** Un atacante envía un gran número de **paquetes ICMP** a una red de computadores usando la **dirección IP de difusión (broadcast)** como destino y **suplantando la dirección IP de la víctima como origen**
 - ✓ Si el número de máquinas de la red que responde a esos paquetes es muy grande, la víctima quedará inundada por tráfico
 - ✓ Esta técnica se conoce como reflexión y amplificación
- **Contramedidas:**
 - Si la víctima está en la misma red destino del Echo Request, el cortafuegos no debe dejar pasar mensajes del exterior con una IP origen de la red interna
 - No aceptar mensajes Echo Request con destino la IP de broadcast
- **Herramientas:** nping, hping...
 - Troyano Smurf: a veces empaquetado en un rootkit, se mantiene inactivo hasta que es activado de forma remota



Protocolos de Encaminamiento

- Estos protocolos se utilizan por los encaminadores (routers) para identificar el camino que debe seguir el paquete para llegar del origen al destino.
- Los protocolos de encaminamiento pueden ser dinámicos o estáticos.
 - ✓ Un protocolo de encaminamiento dinámico puede descubrir rutas y construir una tabla de enrutamiento. Los encaminadores utilizan estas tablas para tomar decisiones sobre la mejor ruta para los paquetes que reciben.
 - ✓ Un protocolo de encaminamiento dinámico puede cambiar las entradas en la tabla en función de los cambios que se producen en las diferentes rutas.
 - Cuando una router que utiliza un protocolo de encaminamiento dinámico descubre que una ruta se ha caído o está congestionada, envía un mensaje de actualización a los otros encaminadores a su alrededor.
 - Los otros encaminadores utilizar esta información para actualizar su tabla de enrutamiento, con el objetivo de proporcionar servicios eficientes.

Encaminamiento

- Los protocolos de encaminamiento no proporcionan **integridad** ni **autenticidad** de origen

Vulnerabilidades

- Se pueden perturbar asociaciones entre encaminadores → *disrupt peering*
- Se pueden **anunciar rutas falsas** (*rogue routes*)
 - Un atacante envía mensajes RA (Route Advertisement) falsos para alterar las tablas de encaminamiento de los routers

Tipos de ataque

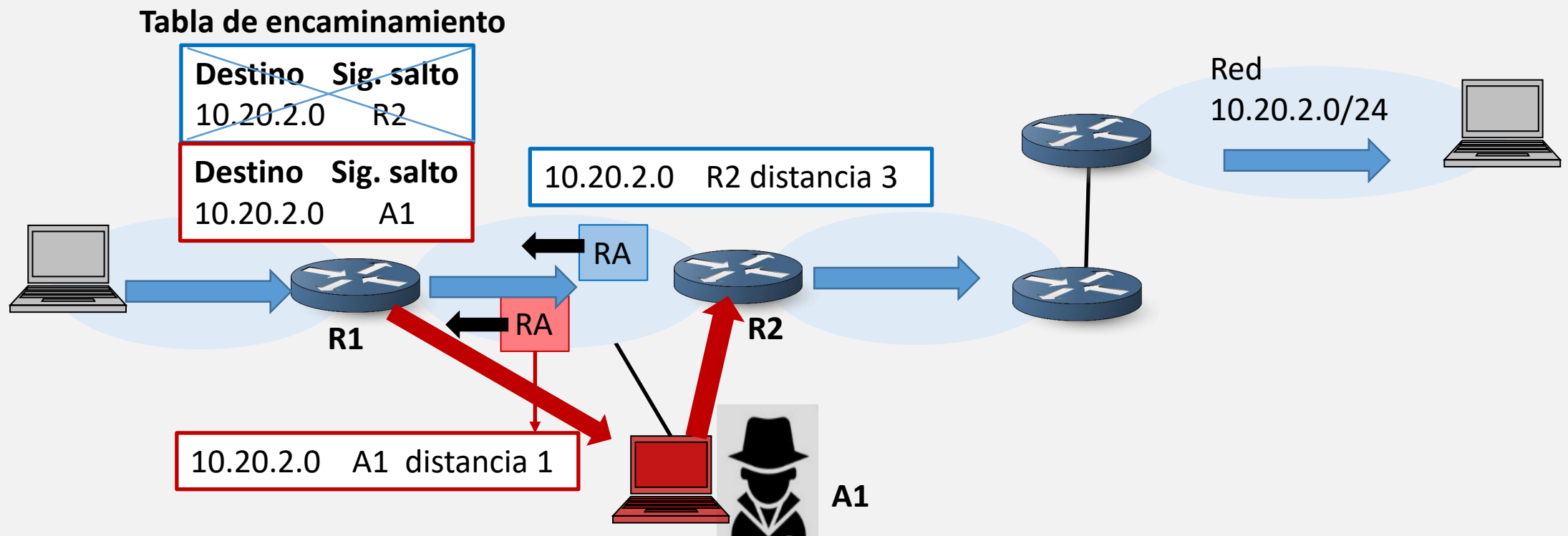
- Intermediario
 - Redirección de paquetes a sistemas maliciosos
- DoS
 - Creación de bucles y “agujeros negros”

Contramedidas

- Autenticación de mensajes
- Seguridad IP (IPsec)

Anuncio de rutas falsas (*Rogue Route Advertisement*)

- **Intermediario:** El atacante se hace pasar por un router y manda un mensaje RA anunciando que está a distancia 1 de la red 10.20.2.0/24.
 - ✓ Los *routers* que reciben este mensaje actualizan su tabla de rutas, así los mensajes con destino la red 10.20.2.0/24 pasarán por el atacante



Encaminamiento

Vulnerabilidades

- Se puede especificar la ruta que debe seguir un paquete en el origen
- No es una vulnerabilidad debida a los protocolos de encaminamiento si no del protocolo IP que permite **encaminamiento en origen** (*source routing*)

Tipos de ataque

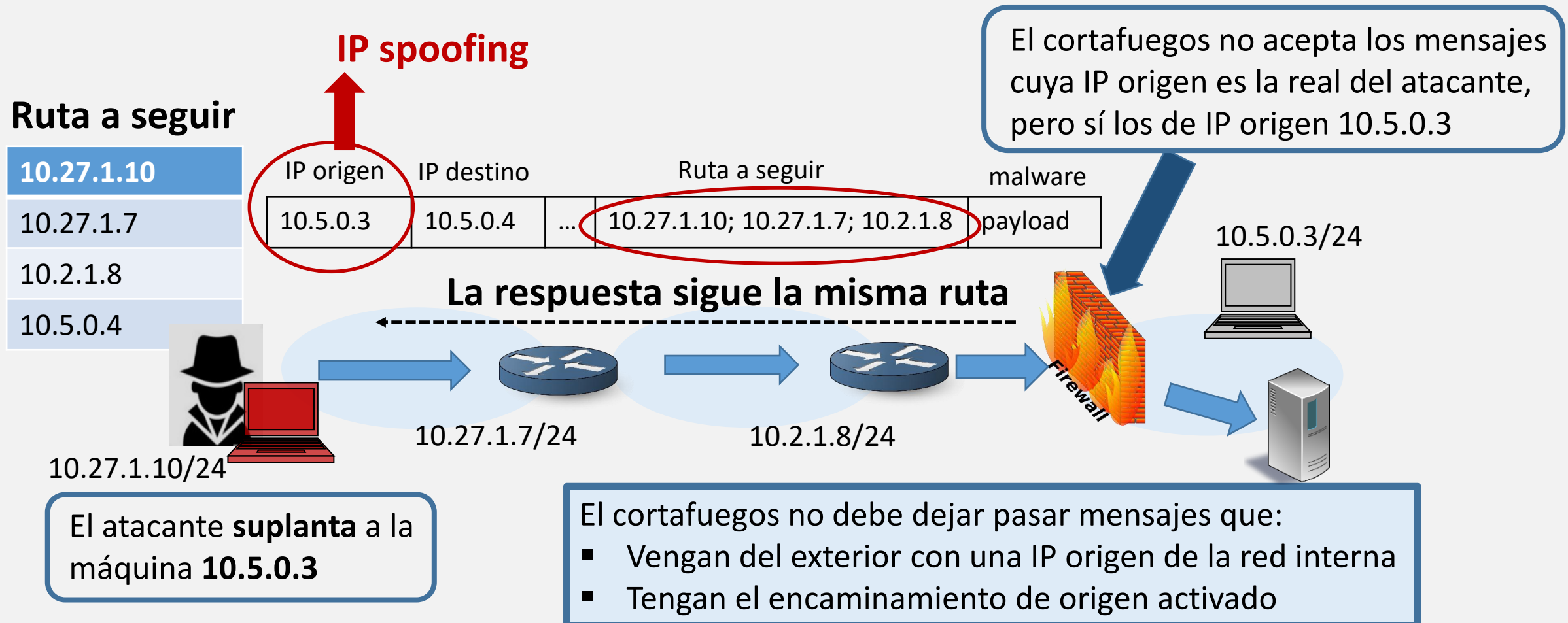
- Intermediario
 - Captura de tráfico de red haciéndolo pasar a través de un sistema controlado por el atacante
- Acceso no autorizado
 - Evasión de cortafuegos o IDS

Contramedidas

- No permitirlo

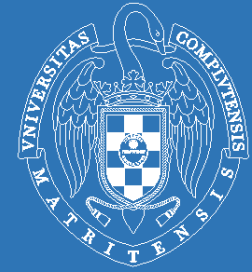
Encaminamiento en origen

- **Escenario:** Un atacante especifica la ruta que debe seguir un paquete en el origen



Módulo 1. Seguridad en redes

Vulnerabilidades en protocolos de red y ataques



CAPA DE TRANSPORTE: TCP, UDP

TCP

- TCP se conoce como un protocolo orientado a la conexión porque, antes de que se envíen datos de la comunicación, se produce un *handshaking* entre los dos sistemas que desean comunicarse.
- Una vez que el protocolo de *handshaking* se completa con éxito, se establece una conexión virtual entre los dos sistemas.
- Muchas veces, TCP es el protocolo de transporte elegido porque proporciona confiabilidad y garantiza que todos los paquetes se entreguen.
 - ✓ Si un paquete llega dañado o no se recibe, se vuelve a mandar.
 - ✓ Esto implica una sobrecarga del sistema.
- TCP es un protocolo de transporte que utilizan las aplicaciones para transmitir sus datos.
- Necesita puertos para comunicarse con las capas superiores y para mantener seguimiento de varias *conversaciones* que tienen lugar simultáneamente.
 - ✓ Los puertos también son el mecanismo utilizado para identificar cómo otras computadoras acceden a los servicios. Cuando se forma un mensaje TCP, la información del encabezado contiene un puerto de origen y un puerto de destino junto con las direcciones IP de origen y destino.
 - ✓ Esto constituye un **socket**, y es cómo los paquetes saben a dónde ir (por la dirección) y cómo comunicarse con el servicio o protocolo correcto en la otra computadora (por el número de puerto).
 - ✓ La dirección IP actúa como puerta de entrada a una computadora y el puerto actúa como puerta de entrada a un servicio de esa computadora.

En TCP

- No proporciona **integridad** ni **autenticidad** de origen

Vulnerabilidades

- Se pueden **suplantar, controlar o reiniciar conexiones** obteniendo o adivinando su estado

Tipos de ataque

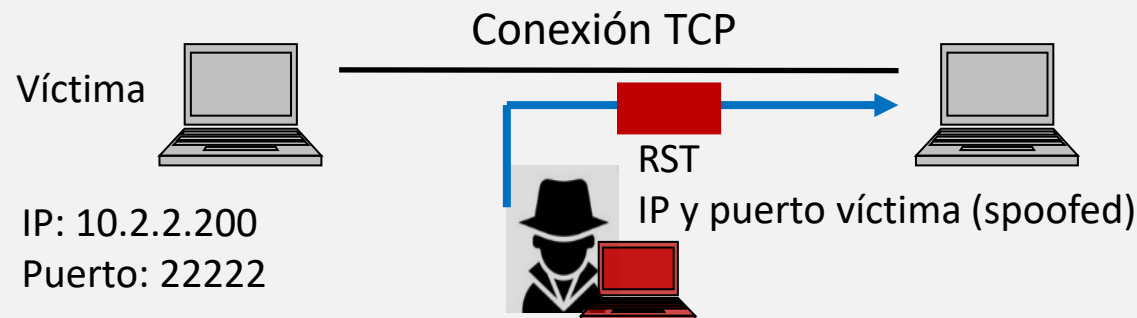
- Acceso no autorizado
- Intermediario
- DoS

Contramedidas

- Números de secuencia aleatorios
- Seguridad de transporte (SSL/TLS)

Finalización de conexiones TCP

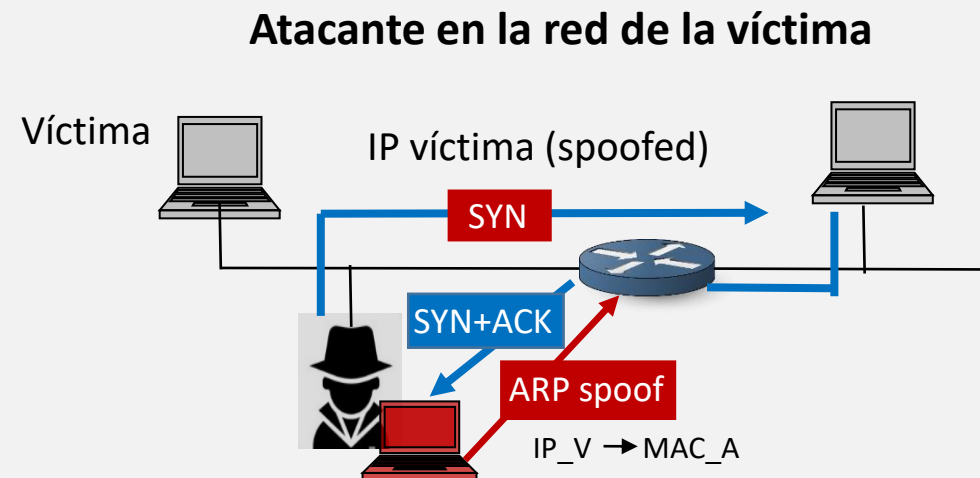
- **Escenario:** Un atacante adivina u obtiene (mediante escucha) los números de secuencia de una conexión existente y envía un paquete RST para cerrarla
 - ✓ La probabilidad de acierto es $1/2^{32}$ (con números de secuencia de 32 bits)
 - ✓ La mayoría de sistemas permiten una ventana mayor de números de secuencia aceptables
- **Ataque: Denegación de servicio**
 - ✓ Ejemplo: protocolo de encaminamiento BGP
 - BGP utiliza TCP para intercambiar información sobre rutas
 - La finalización de una conexión TCP con un router “colega” se interpreta como la pérdida de las rutas a través de él



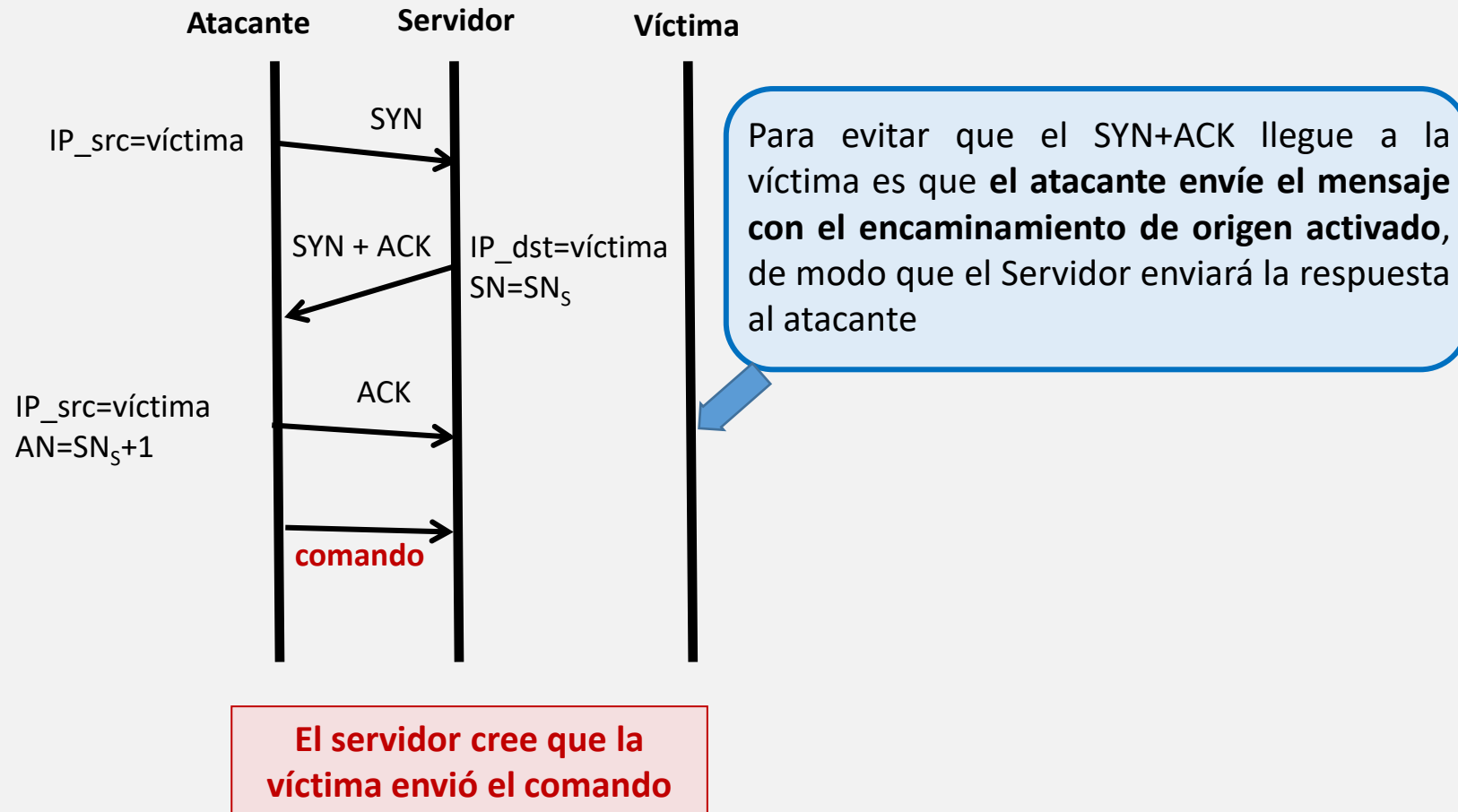
Suplantación de conexiones TCP

- **Escenario:** Un atacante crea una conexión TCP en nombre de una dirección IP origen falsa (**IP spoofing**)
 - ✓ Necesita que la respuesta del servidor (SYN+ACK) no le llegue a la víctima. Esto se consigue:
 - Dentro de la red de la víctima:
 - Engañar al router (**ARP spoofing**)
 - Fuera de la red:
 - Encaminamiento de origen

La víctima no se entera de que alguien ha iniciado una conexión con el servidor en su nombre

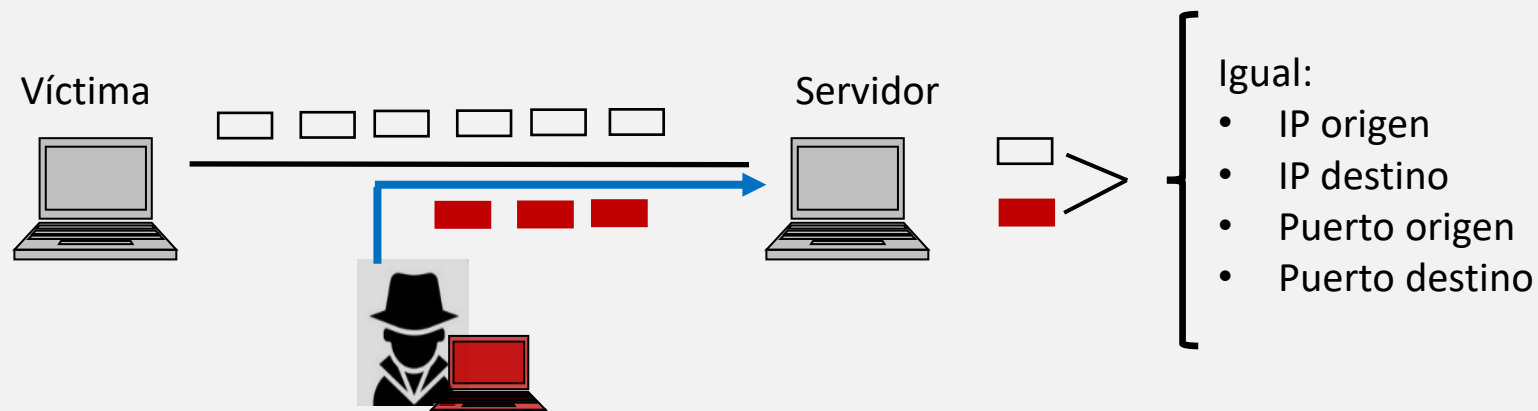


Suplantación de conexiones TCP



Secuestro de conexiones TCP

- **Escenario:** Un atacante toma el **control de una conexión TCP establecida** adivinando u obteniendo los números de secuencia
 - ✓ Normalmente conlleva un ataque de **denegación de servicio** a la víctima para que no siga ni enviando ni recibiendo mensajes
 - ✓ La diferencia con el caso de suplantación es que el atacante aprovecha una conexión ya establecida
- **Herramientas:** ettercap, hunt...



En TCP

- Acuerdo TCP

Vulnerabilidades

- Al consumir recursos, se puede saturar el sistema o impedir nuevas conexiones → **TCP SYN flooding**

Tipo de ataque

- DoS

Contramedidas

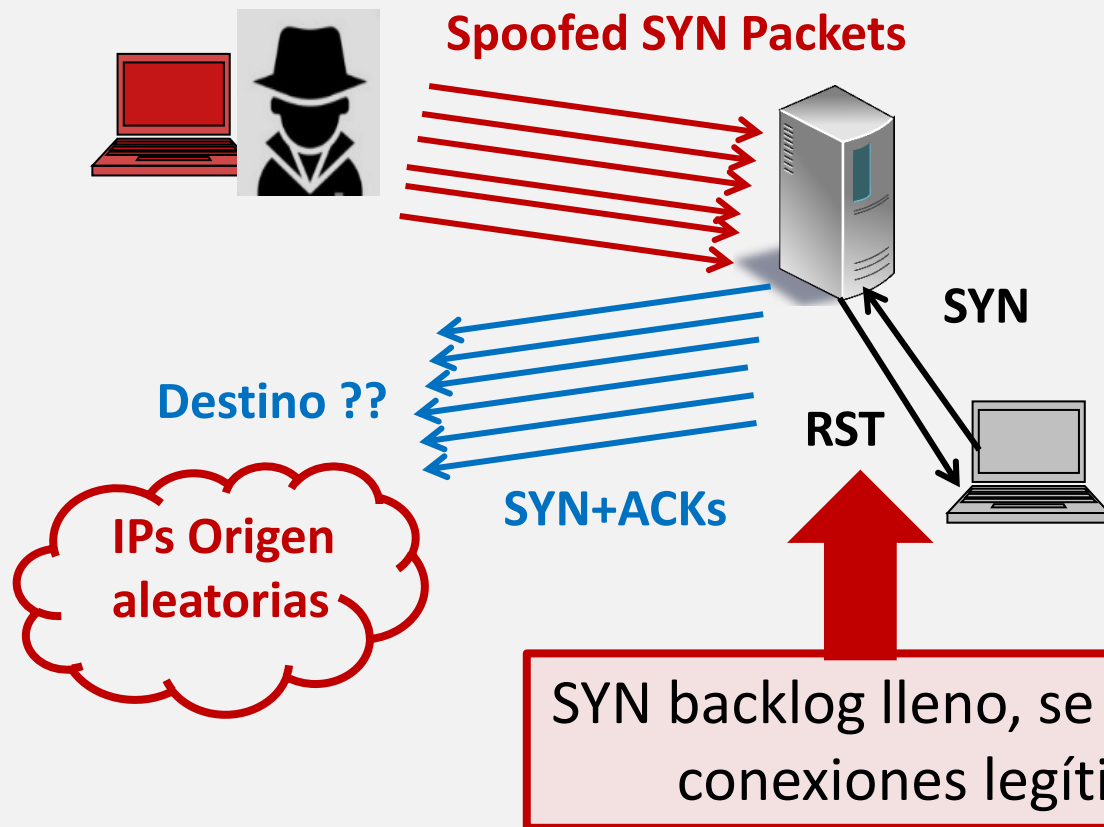
- Cortafuegos
- IDS
- SYN cookies

Inundación TCP SYN (*TCP SYN Flooding*)

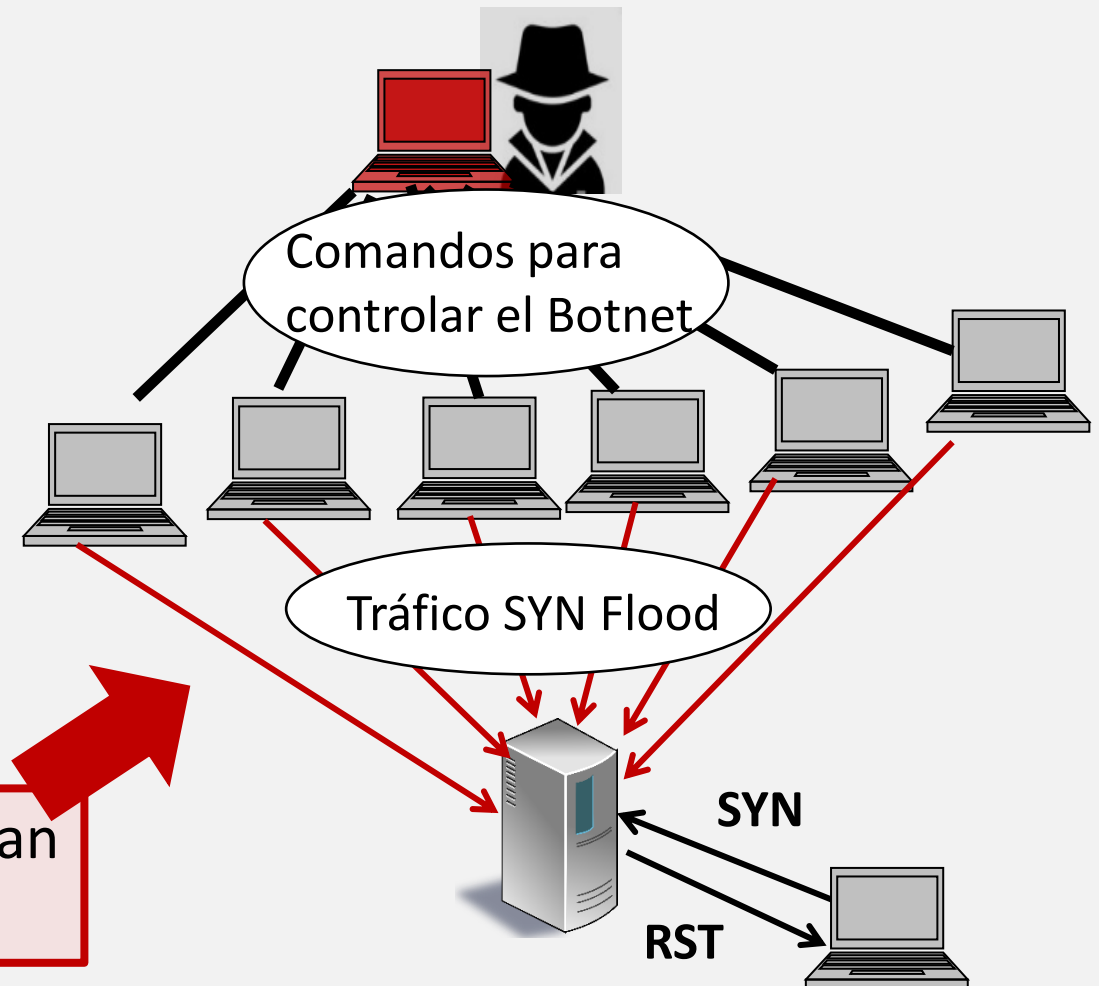
- **Escenario:** Un atacante envía gran cantidad de mensajes SYN a la víctima
- **Tipo de ataque:** **Denegación de servicio**
 - ✓ Llena la cola de conexiones incompletas (*TCP SYN backlog*), impidiendo nuevas conexiones, y consume CPU
- El mecanismo **SYN cookies** mitiga el efecto
 - ✓ Codifica de forma segura el estado de la conexión en el número de secuencia de servidor del mensaje SYN+ACK, que recupera y verifica cuando llega el mensaje ACK final, consumiendo más CPU
- **Herramientas:** nping, hping...

Inundación TCP SYN

Ataque DoS, directo



Ataque DDoS, distribuido



Exploración de redes y puertos

- Envío de peticiones a un sistema para conocer su conectividad.
- Varios protocolos (TCP e ICMP entre otros) ofrecen información sobre la conexión/computadora/servidor como respuesta a una petición de conexión.
- Es considerado un ciberincidente del tipo “obtención de información” si se realiza sobre redes de computadoras que no son de tu organización o sobre las que no tienes permisos de administración.

En TCP

- Revelación de información

Vulnerabilidades

- Se puede **identificar el SO** y los **puertos abiertos** por diferencias de comportamiento o respuestas a peticiones poco convencionales

Tipos de ataque

- Identificación (fingerprinting)
- Exploración de puertos (port scanning)

Contramedidas

- Cortafuegos
- IDS

Exploración de redes y puertos (*Network and Port Scanning*)

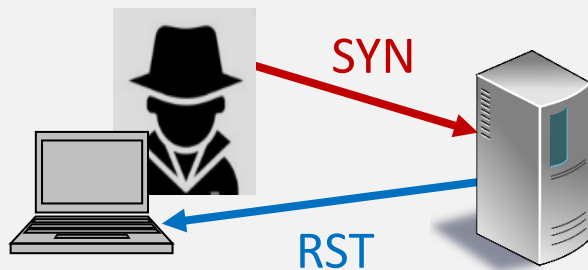
- **Exploración de redes:** Enviar peticiones (*ping*) a un rango de direcciones para encontrar las máquinas activas
- **Exploración de puertos:** Enviar peticiones (SYN, ACK, FIN...) a un rango de puertos de una máquina con el objetivo de encontrar los que están abiertos
- **Enumeración de servicios:** Identificar el servicio, y su versión, ofrecido en un puerto
 - ✓ Si se conoce el servicio y la versión se puede explotar alguna vulnerabilidad conocida
- La mayoría no son ataques, sino que se usan para determinar las máquinas y servicios disponibles en una red (ej. para **auditoría**)
- Cuando se trata de un ataque, estas acciones suelen formar parte de la **fase de reconocimiento del ataque**
- Herramientas: nmap (<https://nmap.org/>)...

Exploración de redes y puertos

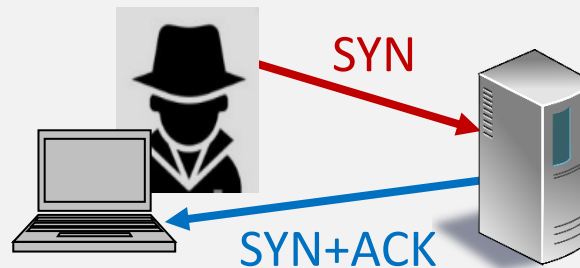
■ ¿Cómo detecta nmap que el puerto 444 está abierto?

- ✓ Con la opción `-sS` envía un mensaje TCP con el flag SYN activo a la máquina víctima
- ✓ Detecta el estado del puerto en función de la respuesta de esta máquina

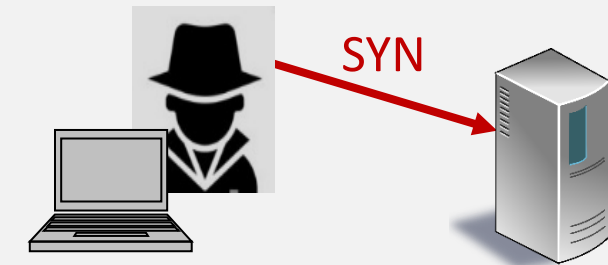
Puerto cerrado



Puerto abierto



Puerto filtrado



UDP

- UDP es un protocolo de transporte que utilizan las aplicaciones para transmitir sus datos.
- UDP se considera un protocolo sin conexión. UDP envía mensajes sin comunicarse primero con la computadora de destino y no sabe si los paquetes se recibieron correctamente o abandonó.
- Requiere menos recursos que el protocolo TCP y presenta también una trama más sencilla.
- Necesita puertos para comunicarse con las capas superiores y para mantener seguimiento de varias *conversaciones* que tienen lugar simultáneamente.
 - ✓ Los puertos también son el mecanismo utilizado para identificar cómo otras computadoras acceden a los servicios. Cuando se forma un mensaje UDP, la información del encabezado contiene un puerto de origen y un puerto de destino junto con las direcciones IP de origen y destino.
 - ✓ Esto constituye un **socket**, y es cómo los paquetes saben a dónde ir (por la dirección) y cómo comunicarse con el servicio o protocolo correcto en la otra computadora (por el número de puerto).
 - ✓ La dirección IP actúa como puerta de entrada a una computadora y el puerto actúa como puerta de entrada a un servicio de esa computadora.

Inundación UDP

- **Escenario:** Un atacante envía gran cantidad de mensajes UDP (normalmente echo o chargen) a la víctima
- **Tipo de ataque:** **Denegación de servicio**
- El ataque *fraggle* usa la misma técnica que **reflexión y amplificación** del ataque *smurf*, pero con **UDP**
 - ✓ El atacante envía gran cantidad de mensajes UDP con la dirección de difusión como destino y suplantando la dirección IP de la víctima como origen
- **Herramientas:** nping, hping...

Módulo 1. Seguridad en redes

Vulnerabilidades en protocolos de red y ataques

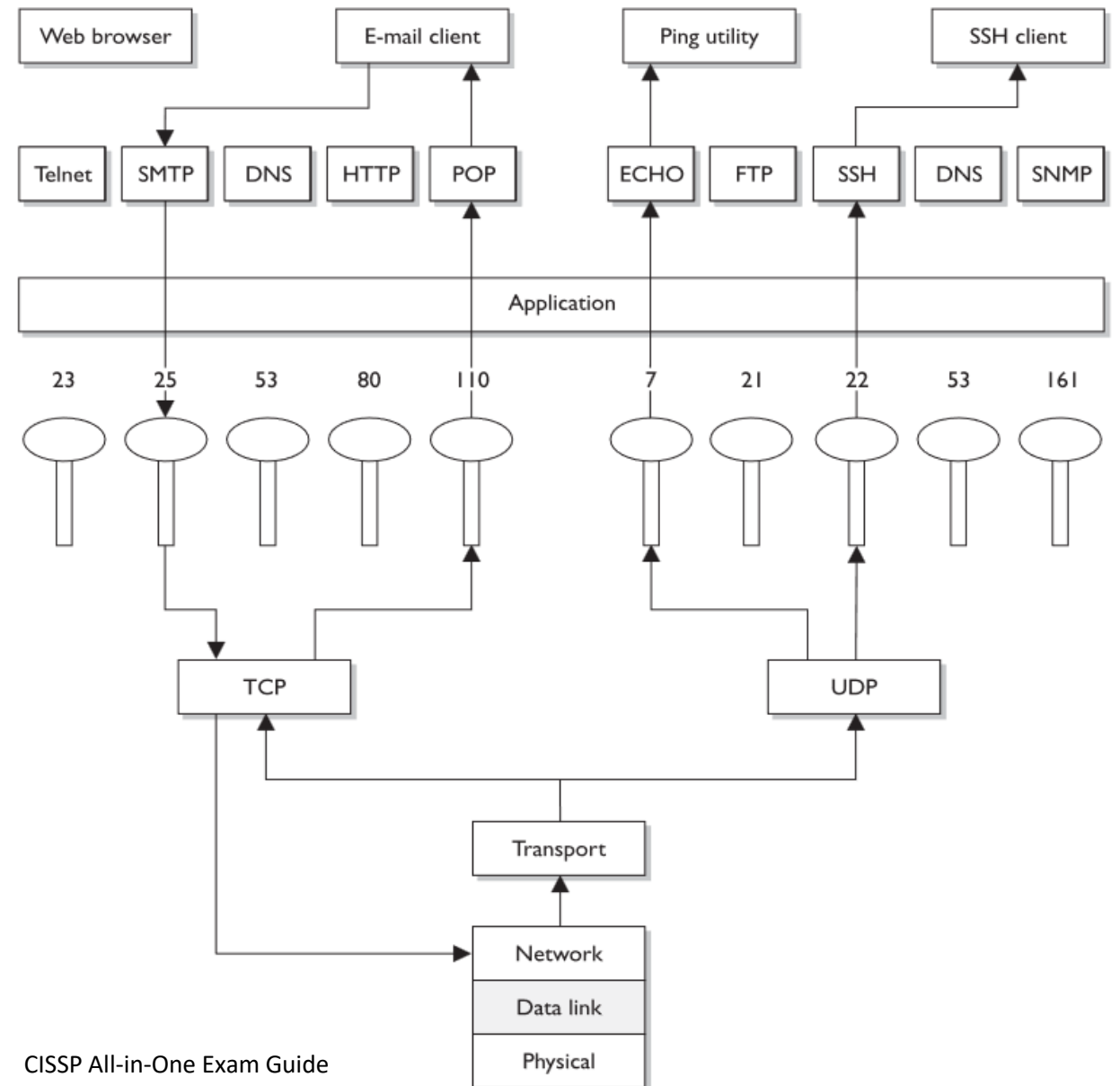


CAPA DE APLICACIÓN: HTTP, DNS

Capa de Aplicación

- Para comunicarse con la capa de aplicación se necesitan puertos.
 - ✓ Los puertos también son el mecanismo utilizado para identificar cómo otras computadoras acceden a los servicios. Cuando se forma un mensaje en la capa de transporte, la información del encabezado contiene un puerto de origen y un puerto de destino junto con las direcciones IP de origen y destino.
 - ✓ Esto constituye un **socket**, y es cómo los paquetes saben a dónde ir (por la dirección) y cómo comunicarse con el servicio o protocolo correcto en la otra computadora (por el número de puerto).
 - ✓ La dirección IP actúa como puerta de entrada a una computadora y el puerto actúa como puerta de entrada a un servicio de esa computadora.

Capa de Aplicación



CISSP All-in-One Exam Guide

Ataques DoS en capa de aplicación

- El atacante trata de explotar vulnerabilidades de la aplicación para agotar la memoria y el tiempo de proceso que necesita la aplicación para su correcto funcionamiento
- Estos ataques se caracterizan por:
 - Necesidad de menor ancho de banda que los ataques SYN Flood
 - Mayor dificultad para diferenciar el tráfico malicioso del legítimo
- Hay ataques de este tipo dirigidos a distintos protocolos de la capa de aplicación: HTTP, DNS, SMTP, SNMP, FTP, etc

Ataques DoS: Protocolo HTTP

■ Fragmentación HTTP

- Un atacante establece una conexión válida con el servidor objetivo, enviando todo el tráfico de datos HTTP en pequeños fragmentos
- El servidor se ve obligado a mantener sesiones activas durante largos periodos de tiempo
- Si el número de conexiones es alto acaba agotando los recursos asignados a la tabla de conexiones

■ Número excesivo de peticiones HTTP

- Consiste en la generación de una alta tasa de peticiones HTTP (GET, PUT, POST, DELETE,...) contra el servidor atacado
- El objetivo es el consumo de los recursos del servidor usando peticiones que, a priori, no se pueden diferenciar de peticiones legítimas
- Se puede maximizar el efecto solicitando, por ejemplo, archivos de gran tamaño

Herramienta
Solaris



Funcionamiento

1. Hace muchas peticiones HTTP
2. Envía cabeceras periódicamente (cada ~15 segundos) para mantener las conexiones abiertas
3. Nunca se cierra la conexión. Si la cierra el servidor, se crea una nueva y se sigue haciendo lo mismo

Ataques al protocolo DNS

■ Ataques DoS por inundación DNS

- El atacante inunda los servidores DNS de un dominio para intentar interrumpir la resolución de DNS para ese dominio
- Al interrumpir la resolución de DNS, un ataque de inundación de DNS comprometerá la capacidad de un sitio web, API o aplicación web para responder al tráfico legítimo

■ Ataques de envenenamiento DNS cache

- Se puede modificar la información almacenada en un servidor DNS cache (relación nombre de dominio-dirección IP) para redirigirnos a un servidor propiedad del atacante o para denegarnos el acceso a un servidor (ataque DoS)

Redes inalámbricas

Vulnerabilidades

- Se puede leer el tráfico
- Se puede inyectar tráfico
- Se puede falsificar la dirección MAC (*MAC spoofing*)
- Se pueden crear puntos de acceso falsos (*rogue access points*)
- Sensibles al ruido (DoS inevitable)

Ejemplos de ataques

- Escucha de tramas (frame sniffing)
- Inyección de tramas (frame injection)
- Obtención de contraseñas (password cracking)
- Punto de acceso falso (rogue access point)

- **Herramientas:** aircrack-ng...